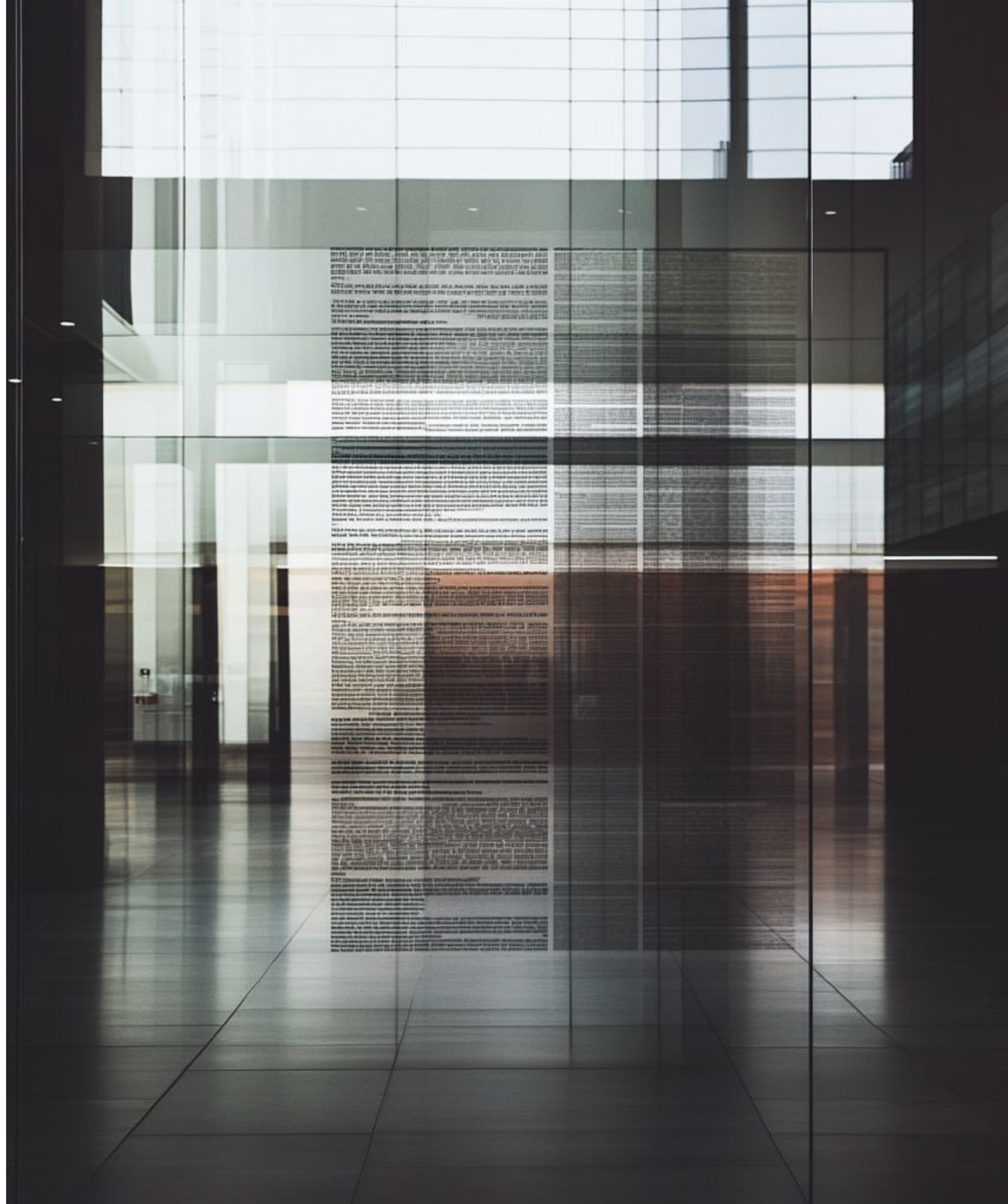


1. OVERVIEW

An overview of Requirement 7 (“Need-to-Know Access”), and its sub-requirements.



REQ. 7: NEED-TO-KNOW ACCESS

REQ. 7: NEED-TO-KNOW ACCESS **OVERVIEW**

Requirement 7 (Restrict Access to System Components and Cardholder Data by Business Need to Know) is all about restricting access to data, as much as possible.

- It follows the PoLP, or Principle of Least Privilege. Everyone must see the minimum data possible to perform what they are doing, and for the least amount of time possible;
- If the person must only see the full PAN, allow them to just see it. If they can only see a masked PAN, allow only that;
 - If they can do their job without seeing anything... do it;

This requirement focuses mostly on:

- Minimizing the data people see, and for how long;
- Formalizing all of this with roles, access control rules, etc;

REQ. 7: NEED-TO-KNOW ACCESS **OVERVIEW**

The sub-requirements for this requirement include:

- 7.1 Processes and mechanisms for restricting access to system components and cardholder data by business need to know are defined and understood.
- 7.2 Access to system components and data is appropriately defined and assigned.
- 7.3 Access to system components and data is managed via an access control system(s).





REQ. 7: NEED-TO-KNOW ACCESS

REQ. 7: NEED-TO-KNOW ACCESS **OVERVIEW**

7.1 Processes and mechanisms for restricting access to system components and cardholder data by business need to know are defined and understood

- This our usual sub-requirement. All processes and policies regarding need-to-know access to data must be documented and enforced, as must be the definitions of roles and responsibilities for these;

This is usually tested through:

- Examination of documentation, and interviewing of personnel, to verify that everything is properly documented and followed;

REQ. 7: NEED-TO-KNOW ACCESS **OVERVIEW**

7.2 Access to system components and data is appropriately defined and assigned

- Users must have access to CHD based on their specific role/job functions, and it must be the least possible;
- All user accounts and their respective privileges must be periodically reviewed (including admins, vendors, third parties);
- With exceptions, users can't directly query CHD repositories;

This is usually tested through:

- Examining role definitions, review procedures and records;
- Interviewing personnel responsible for definition of AC rules and execution of AC privilege reviews;





REQ. 7: NEED-TO-KNOW ACCESS

REQ. 7: NEED-TO-KNOW ACCESS **OVERVIEW**

7.3 Access to system components and data is managed via an access control system(s)

- We must have a system to perform access control (Active Directory, LDAP, Access Control Lists. The specific system isn't mandated, but it must be working and enforcing the defined privileges for each role;
- It must "deny all", by default;

This is usually tested through:

- Examining vendor documentation and system settings to ensure the system is running, and enforcing privileges;
- Examining that the system is configured to "deny all", by default;

REQ. 7: NEED-TO-KNOW ACCESS **OVERVIEW**

How can we summarize, then, this requirement?

- People should access the minimum possible data to do their job, which is formally defined in access control privileges;
- AC privileges should be strict and based on personnel's role/job functions, and periodically reviewed. This includes accounts for external third parties, too;
- We must have a system to manage the AC privileges defined, that is running and enforcing said privileges, and that otherwise "denies all" by default;



REQ. 7: NEED-TO-KNOW ACCESS

OVERVIEW

EXAMPLES

/01 REDUCE, REDUCE, REDUCE

There are many situations where employees are not required to have access to different components of CHD or different systems. Attention to detail is key.

/02 COMMON SENSE SYSTEMS

The choice of which system to use for access control, from Active Directory to LDAP is subjective, as long as it does its job and enforces access control in practice.

/03 CHANGE-MANAGED

Changes in access control should not be performed “unofficially”, but through formal change management process, reflected in the system.

REQ. 7: NEED-TO-KNOW ACCESS

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization restricts access to the PoS system and associated data to only staff members that need it to perform their job duties, and only during payments;
- Access permissions are granted based on job roles (e.g., cashier, manager), with each role only seeing the minimum data possible, and just for specific tasks;

E-COMMERCE STORE

- The organization limits administrative access to the website, and associated servers, to essential personnel that need it for their tasks;
- The organization limits database access of DBs with CHD to authorized roles only, such as DBAs;
- User accounts/access rights are reviewed quarterly;

HOTEL CHAIN

- The organization establishes centralized identity and access management solutions for all hotel locations;
- Access level is defined based on job functions (front desk, IT support, etc) for roles in all locations;
- Policies are defined to promptly revoke access to CHD and critical systems;

PAYMENT PROCESSOR

- The organization implements policies to grant and revoke access to data by role, with tasks and lengths of data access associated with these;
- Granular access control mechanisms define exact permissions for exact data repositories, data fields, and metadata per role (e.g., only Customer Name + Address);

REQ. 7: NEED-TO-KNOW ACCESS

OVERVIEW

KEY TAKEAWAYS

/01 THE LEAST POSSIBLE

This requirement is all about having the least possible privileges. Only what the person needs to know. And having systems in place for consistent enforcement.

/03 7.2 AC PRIVILEGES

AC privileges must be the minimum possible, must be defined by role/job functions, and must be periodically reviewed.

/02 7.1 PROCESSES DEFINED

As usual, all of these processes and policies must be defined and in use, and the same for definitions of roles and responsibilities of personnel working on this.

/04 7.3 AC SYSTEM

There must be a formal system to enforce these AC privileges, and that otherwise “denies all” privileges by default.